PHP发生了什么?

01 / 概览 | PHP2Shell：支撑网站运行的PHP本身出现问题

登录前也可能遭到攻击
2026年10月21日，PHP开发团队发布了两项严重漏洞的修复版本。条件满足时，未经身份验证的攻击者可能在服务器上执行非法代码。

什么是PHP?
WordPress等系统使用的服务器端编程语言，负责生成页面和处理输入内容。

CVE-2026-109618
内存不足时的处理可能使内部数据处于不完整状态，非法内存操作可能导致代码执行。

CVE-2026-109619
与已释放内存有关的旧内部状态可能残留，并在后续请求中被使用，从而可能导致代码执行。

两项严重性评分均为9.2 / 10
按CVSS v4.0属于“严重”。实际攻击是否成功也取决于架构和配置。

仅加强管理后台密码无法从根本上防御。
TODOROKI / 网络安全 / 2026.10.23

有哪些危险?

02 / 风险 | 损害范围取决于PHP的权限及可访问的信息

01 信息泄露
服务器配置、身份凭据以及可连接数据库中的信息等可能被窃取。

02 网站遭到篡改
页面或链接被改写、设置虚假输入页面等，也可能使损害波及用户。

03 服务停止及入侵长期化
干扰处理或植入恶意文件可能造成营业中断或再次入侵。

不只是WordPress
PHP官方广泛提醒处理网络请求的PHP环境注意，包括PHP-FPM、Apache的mod_php、php-cgi、FrankenPHP、LiteSpeed等。

尤其是mod_php，已有在应用代码运行前攻击便能成功的演示案例。仅设置登录页面并不能放心。

这里列出的是可能的损害，并不意味着所有网站都已被入侵。
TODOROKI / 网络安全 / 2026.10.23

根本对策是更新PHP本身

03 / 更新 | 与WordPress本体及插件更新分开确认

包含本次修复的版本
PHP 8.2：8.2.35
PHP 8.3：8.3.36
PHP 8.4：8.4.27
PHP 8.5：8.5.12

使用同系列上述修复版及之后的版本，或使用发行方已应用本次修复的软件包。不要只凭显示的版本判断，也要查看提供方公告。

确认 → 保全 → 更新 → 检查
1. 在服务器控制面板或向签约服务商确认是否使用PHP及修复状况。
2. 备份文件和数据库，确认兼容性。
3. 更新PHP，重启必要进程，检查有无遗漏更新。
4. 检查页面显示、登录行为以及可疑文件和通信。

PHP 8.1及更早版本的常规支持已经结束。应向发行方确认修复供应情况，并推进迁移到仍受支持的系列。

租用服务器应确认：“本次两个CVE是否已经处理？”
TODOROKI / 网络安全 / 2026.10.23

无法更新时怎么办?

04 / 行动 | 应急措施、入侵后处理及普通用户可做之事

不要仅凭应急措施判断“安全”
官方有可减少部分攻击路径的配置变更，但彻底解决只能靠更新。应与管理员商量，并考虑限制访问或暂时停止相关服务。

不要照抄配置值
禁用上传进度功能等只是针对特定路径的缓解措施。调整内存限制也可能影响可用性，须结合整体环境判断。

怀疑已遭入侵，不能更新后就结束
修复版本不会自动删除已经植入的恶意文件。应保全日志等证据，调查入侵范围；必要时从安全环境恢复并更换身份凭据。

普通用户应查看官方指引
对方服务器由运营方修复。应查看服务警示，在不自然的登录或支付页面停止输入。按公告办理手续时，应通过官方应用或已知的官方网站进入。

仅仅“显示正常”并不能判断安全性。
TODOROKI / 网络安全 / 2026.10.23